Profils utilisateurs - pili-pos

Le Manuel de certification SCE 2.0 (Introduction, p.9) impose **trois profils d'accès** distincts au système :

- **Gérant / Technicien** ("Manager / Technicien")
- **Serveur**
- **Apprenti**

Le présent document établit la correspondance entre ces profils attendus par le SPF Finances et les rôles techniques implémentés dans `crates/pos-core/src/user.rs`.

1. Correspondance des profils

Profil SCE 2.0	Rôle technique `pili-pos`	Code source
Gérant / Technicien	`UserRole::Admin`	`crates/pos-core/src/user.rs:6`
Serveur	`UserRole::Cashier`	`crates/pos-core/src/user.rs:7`
Apprenti	`UserRole::Waiter`	`crates/pos-core/src/user.rs:8`

Chaque utilisateur du POS est stocké dans la table `users` (`crates/pos-db/src/schema.rs`) avec : - son numéro INSZ à 11 chiffres (clé primaire, validé par `validate_insz` dans `crates/pos-core/src/user.rs:46`) ; - son rôle (`admin` / `cashier` / `waiter`) ; - un hash bcrypt de son code PIN (facultatif) ; - un drapeau `active` pour désactiver un utilisateur sans le supprimer (la suppression n'est autorisée que pour les utilisateurs n'ayant jamais effectué d'événement fiscal - voir §III.C).

2. Capacités par profil

2.1 Gérant / Technicien (`Admin`)

Accès complet. Concrètement, peut :

- Effectuer toutes les opérations d'un Serveur (ci-dessous).
- Générer un rapport X (à tout moment de la journée).
- Générer un rapport Z (clôture de journée fiscale).
- Saisir un Money-in / Money-out (Événement F - fonds de caisse, pourboires, retrait).
- Ouvrir le tiroir-caisse hors-vente (Événement F-WAR - drawer-open).
- Émettre une copie de ticket (Événement C).
- Effectuer un remboursement complet (Événement N, M111) ou partiel (M112B - événement séparé, voir `REFUND_FLOW.md`).
- Activer / désactiver le mode formation (Événements T), uniquement lorsqu'aucune commande avec des lignes n'est ouverte : une table réelle ne peut ainsi jamais être encaissée en formation, ni une commande de formation encaissée comme une vente réelle.
- Accéder à la vue Paramètres (`SettingsView.vue`) et à la vue Rapports.
- Créer des utilisateurs (Gérant, Serveur ou Apprenti), en désactiver (jamais soi-même ; jamais de suppression : l'INSZ reste sur les événements signés) et réinitialiser leur PIN. Créer un Gérant ou changer le PIN d'un autre employé demande le PIN du Gérant connecté.

2.2 Serveur (`Cashier`)

Profil d'opérateur de caisse standard. Peut :

- Se connecter avec INSZ + code PIN (Événement S - `signWorkIn`).
- Se déconnecter (Événement S - `signWorkOut`).

- Ouvrir / réutiliser une table en cours.
- Ajouter, retirer ou modifier les lignes d'une commande ouverte.
- Enregistrer la commande (Événement P - `signOrder`).
- Imprimer un pré-ticket (Événement P - `signPreBill`).
- Encaisser : encaissement comptant ou carte (Événement N - `signSale`). Tiroir s'ouvre automatiquement pour les paiements comptant.
- Modifier son propre PIN.

2.3 Apprenti (`Waiter`)

Profil restreint. Peut :

- Se connecter / se déconnecter.
- Ouvrir / réutiliser une table.
- Ajouter, retirer ou modifier les lignes d'une commande ouverte (chaque correction est journalisée et transmise au FDM).
- Enregistrer la commande (Événement P - `signOrder`).
- **NE peut PAS** imprimer l'addition ni encaisser : les boutons « Addition » et « Payer » ne lui sont pas présentés, et le backend refuse la commande (code `forbidden`) ; un Serveur ou un Gérant encaisse.
- **NE peut PAS** générer de rapport, copier un ticket, rembourser, ouvrir le tiroir, ni modifier les paramètres.

3. Mécanismes d'enforcement

L'enforcement vit à deux niveaux :

1. **Niveau commande Tauri** (couche autoritative, `src-tauri/src/commands/access.rs`). La connexion (`login`, INSZ + PIN) ouvre une session côté backend ; la déconnexion (`logout`, après le pointage de sortie) la ferme. Chaque commande qui signe un événement fiscal, modifie un paramètre ou gère les utilisateurs vérifie d'abord le rôle de l'opérateur connecté :

Accès	Rôles	Commandes
Personnel	Gérant, Serveur, Apprenti	pointage (S), commandes et lignes, enregistrement de commande (P)
Encaissement	Gérant, Serveur	addition (P), vente (N), impression d'un original manquant
Gestion	Gérant	remboursement, copie (C), mouvements de caisse et tiroir (F), rapports X/Z (R), mode formation, utilisateurs, sauvegarde

   Une commande refusée renvoie le code `not_logged_in` (aucune session) ou `forbidden` (rôle insuffisant) avant tout appel au FDM : aucun compteur ni aucune donnée n'est modifié. L'écran affiche le message correspondant dans la langue de l'interface (« Session fermée : reconnectez-vous. », « Action réservée à un autre profil. »), voir `src-tauri/src/commands/errors.rs`.

2. **Niveau UI** (`ui/src/stores/auth.ts`) : les boutons et écrans qu'un rôle ne peut pas utiliser ne lui sont pas présentés (Payer et Addition pour l'Apprenti ; Rapports et Config pour l'Apprenti et le Serveur). Cette couche est purement ergonomique.

L'INSZ de chaque événement est celui de l'opérateur connecté : une commande qui nomme un autre opérateur (pointage, remboursement, copie, mouvement de caisse, rapport) est refusée (code `not_the_operator`). Une vente est signée au nom du Serveur ou du Gérant qui encaisse, même si la commande a été prise par un autre membre du personnel.

Ces règles sont couvertes par `src-tauri/tests/access_control.rs` (chaque rôle, chaque commande, sessions, PIN, formation).

4. Journal des accès

Chaque connexion (Événement S - `signWorkIn`) et chaque déconnexion (Événement S - `signWorkOut`) est consignée dans la table `fiscal_events` avec : - `event_type = 'S'` - `user_insz` = INSZ de l'opérateur - `created_at` = horodatage de l'événement - `fdm_response_json` = réponse signée du FDM

Ces lignes constituent le **journal Dimona-compatible** exigible par l'ONSS et utilisable pour reconstruire intégralement les heures de présence du personnel.

5. Politique de mots de passe

- Les PINs sont stockés sous forme de hash bcrypt (coût 12) dans la colonne `users.pin_hash`. Le PIN lui-même n'est jamais stocké en clair ni journalisé.
- Un Gérant (`admin`) a toujours un PIN : sans PIN, la caisse refuse sa connexion et lui fait choisir un PIN (saisi deux fois), enregistré en même temps que la session s'ouvre (`commands/auth.rs::do_login_with_new_pin`). Une fois choisi, ce chemin est refusé : personne ne peut s'approprier une tuile qui a déjà un PIN. Ce choix à l'écran de connexion n'existe que tant qu'aucun Gérant n'a de PIN (première mise en service) : ensuite, un Gérant sans PIN reçoit le sien d'un autre Gérant dans Paramètres (`first_pin_needs_manager` à l'écran de connexion), et un nouveau Gérant est créé avec son PIN, confirmé par le PIN du Gérant qui le crée.
- Après 5 PIN incorrects de suite pour un même employé (connexion ou confirmation par PIN), la caisse refuse tout essai, même le bon PIN, pendant 30 secondes, puis le double à chaque nouvel échec, jusqu'à 15 minutes (`pin_locked`, avec le temps restant à l'écran). Un PIN correct remet le compteur à zéro ; un redémarrage aussi (`commands/access.rs::verify_pin`).
- Pour un Serveur ou un Apprenti, le PIN n'est pas obligatoire (utile pour un apprenti en période d'essai) ; un avertissement s'affiche à chaque connexion sans PIN. Le drapeau `has_pin` (calculé) informe le frontend de présenter ou non le pavé numérique de PIN.
- L'identité système `00000000029` (robot, enregistrements automatiques) ne peut jamais ouvrir de session et n'a pas de tuile.

6. Limitations connues

- Pas de distinction entre Gérant et Technicien : les deux utilisent le rôle `admin`. Le manuel SCE 2.0 ne les distingue pas dans la matrice de capacités ; les deux profils ont accès complet.